

מודול 15 — הנדסה חברתית ופישינג — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 15: הנדסה חברתית ופישנינג
2.  פתרונות מלאים — מודול 15: הנדסה חברתית ופישנינג

🎯 תרגילים — מודול 15: הנדסה חברתית ופשינג

⚠️ **אתיקה קריטית!** תרגל רק על עצמך, על מעבדה שלך, או בהרשאה מפורשת בכתב. פשינג של אדם/ארגון ללא רשות = עבירה פלילית ופגיעה באנשים אמיתיים. אל תשלח מיילים מזויפים לאיש ללא אישור. פתרונות ב- `solutions.md`.

🚦 לפני שמתחילים — קרא אותי!

- מה צריך: **Kali** (יש בו SET, theHarvester); לתרגילי הקמפיין — **GoPhish**. לכל הפעולות המעשיות — רק על עצמך / מעבדה / בהרשאה בכתב.
- איך עובדים: קרא קודם את ה- `README.md`. למשימות עם כלי — הפקודה מופיעה; לרעיונות 💡 רמז ו-✅ קריטריון.
- נתקעת? רוב התרגילים כאן הם מחקר וכתובה, לא "פריצה". קרא את הסעיף ב-`README`, ואז הצץ ב- `solutions.md`.
- טיפ: זכור תמיד את הצד האתי — המטרה חינוך והגנה, לא לפגוע.

🌐 איפה לתרגל — שתי דרכים

- **TryHackMe** (בדפדפן, ללא התקנה): **Phishing** (מודול) · "OhSINT"
- **Kali** (מקומי): **SET / GoPhish** מקומית — במעבדה ובהרשאה בלבד.

מקרא רמות: 🟢 קל · 🟡 בינוני · 🟠 מתקדם · 🔴 אתגר

🎮 האתגר הגדול — סימולציית פשינג

תכנן ותריץ קמפיין פשינג מבוקר (על עצמך / בהסכמה) עם GoPhish — ומדוד כמה אנשים לחצו. תראה בעיניים למה הגורם האנושי הוא החוליה החלשה.

🏆 **אתגר:** בנה מייל + דף נחיתה, שלח לקבוצת הסכמה, ומדוד אחוז לחיצה. ⚠️ **אתיקה:** רק בהרשאה, ודיווח ללא שמות. + חדר OSINT מומלץ: **OhSINT**. ✅ הצלחה: הרצת קמפיין ומדדת תוצאות — כמו

חלק א' — עקרונות (🟢)

15.1 — רשום את ששת עקרונות ההשפעה של צ'לדיני, ולכל אחד דוגמה לניצול בפישנינג. 💡 רמז: README §15.2 (הטבלה). ✅ הצלחה: 6 עקרונות + דוגמה לכל אחד.

15.2 — הסבר את ההבדל בין Whaling ו-Phishing, Spear Phishing. איזה הכי יעיל ולמה? 💡 רמז: README §15.3. ✅ הצלחה: הבחנת נכון; Spear Phishing הכי יעיל (מותאם אישית).

15.3 — נתח מייל פישנינג אמיתי מתיקית הספאם שלך. זהה 4 סימני אזהרה. 💡 רמז: README §15.5 (סימני הזהוי). רחף מעל הלינקים לבדוק את ה-URL האמיתי. ✅ הצלחה: זיהית 4 סימנים (דומיין שגוי, דחיפות, שגיאות, לינק מטעה...).

חלק ב' — OSINT ותכנון (🟡)

15.4 — בצע OSINT על עצמך (או חברה בהסכמה).

```
theHarvester -d <domain> -b all
```

👁️ **חפש:** מיילים, שמות ותת-דומיינים שהכלי מצא. + חפש ב-LinkedIn. ✅ הצלחה: הפתעת מכמות המידע הציבורי שקיים.

15.5 — נסח מבנה מיילים של ארגון (first.last@) והסבר איך OSINT עוזר לנחש כתובות. 💡 רמז: README §15.4. ✅ הצלחה: הסברת איך מדפוס אחד מרכיבים כתובות לכל העובדים.

15.6 — כתוב טקסט של מייל ספיר-פישנינג ("איפוס סיסמת IT"). אילו עקרונות ההשפעה שילבת? 💡 רמז: README §15.2, §15.5. שלב סמכות + דחיפות. ✅ הצלחה: מייל משכנע + זיהוי העקרונות שהשתמשת בהם.

חלק ג' — קמפיין מבוקר (🟠)

15.7 — התקן והרץ GoPhish, צור Landing Page ו-Template במעבדה שלך בלבד.

```
./gophish https://localhost:3333 -ממשק ב #
```

🔗 רמז: Import Site → Landing Pages → README §15.6 (שבט) → Capture Credentials. הצלחה: יש ✓
לך Template ו-Landing Page מוכנים.

15.8 — הרץ קמפיין ניסיוני על עצמך ובדוק שהמדדים נרשמים. 📌 רמז: README §15.6. צור Group עם המייל שלך בלבד, הרץ Campaign, בדוק Results. הצלחה: ראית מדדי פתיחה/לחיצה נרשמים בדוח. ✓

15.9 — הסבר כיצד evilginx עוקף MFA. 📌 רמז: reverse proxy. README §15.7. שגונב את ה-session cookie. הצלחה: הסברת מדוע 2FA לא עוצר פישנינג מתקדם. ✓

🔴 אתגר מסכם — “תרגיל מודעות פישנינג (מבוקר)”

תכנן קמפיין הדרכת מודעות מלא על ארגון פיקטיבי (או מעבדה בהסכמה):

1. OSINT — אסוף “מטרות” (רשימה פיקטיבית) ומבנה מיילים.
 2. תסריט (Pretext) — בחר תרחיש אמין (IT / HR / משלוח).
 3. בנה ב-GoPhish: Template + Landing Page + Group.
 4. הרץ על כתובות שלך/הסכמה, ואסוף מדדים.
 5. תעד דוח: אחוזי פתיחה/לחיצה/מסירה, בלי שמות, + המלצות. כתוב את קטע האתיקה — איך תציג תוצאות מבלי לבייש עובדים.
- 📌 רמז: מבנה דוח מלא + דגשי אתיקה ב-solutions.md. הצלחה: דוח מודעות עם מדדים (ללא שמות) והמלצות + קטע אתיקה. ✓

📦 דוח מודעות פישנינג הוא תוצר מרכזי בבדיקות PNPT. הדגש את הצד המחקר.

✓ רשימת בקרה — לפני מעבר למודול 16

- ☐ אני מכיר את עקרונות ההשפעה ומזהה אותם בהתקפות
- ☐ אני מבחין בין Phishing/Spear/Whaling/Vishing/Pretexting
- ☐ אני מבצע OSINT לאיסוף מטרות (theHarvester, LinkedIn)
- ☐ אני מזהה סימני מייל פישנינג
- ☐ אני בונה קמפיין מבוקר ב-GoPhish ומודד תוצאות
- ☐ אני מבין evilginx ועקיפת MFA
- ☐ אני יודע לנהל את הבדיקה אתית (Scope, דיווח ללא שיימינג)

פתרונות מלאים — מודול 15: הנדסה חברתית ופשינג

נסה לבד ב-missions.md קודם. רק על עצמך / מעבדה / בהרשאה בכתב.

חלק א' — עקרונות

15.1 Reciprocity — “צירפתי לך קופון, אשר את הפרטים”. - **Commitment** — סקר קצר → בהמשך בקשת סיסמה. - **Social Proof** — “כל המחלקה כבר עדכנה את הפרטים”. - **Authority** — “מדבר מנהל ה-IT / הבנק”. - **Liking** — בניית קרבה בצ'אט לפני הבקשה. - **Scarcity** — “הקישור בתוקף ל-24 שעות בלבד”.

15.2 Phishing = המוני וגנרי; **Spear Phishing** = ממוקד ומותאם אישית; **Whaling** = ספיר-פשינג לבכיר. **Spear Phishing הכי יעיל** — התאמה אישית (שם, תפקיד, פרויקט) מעלה דרמטית את שיעור הלחיצה.

15.3 — סימנים: דומיין שולח שגוי, דחיפות/איום, שגיאות כתיב, לינק שה-URL שלו שונה מהטקסט, בקשת פרטי התחברות.

חלק ב' — OSINT ותכנון

15.4

```
theHarvester -d company.com -b all
# + LinkedIn (עובדים/תפקידים), GitHub, Google Dorking
```

לרוב מפתיע כמה מידע ציבורי קיים: מיילים, מבנה ארגוני, טכנולוגיות.

15.5 — מזהים דפוס מ-OSINT (מייל אחד שדלף) → `firstname.lastname@` → מרכיבים כתובות לכל העובדים שמצאת ב-LinkedIn.

15.6 — דוגמה: “מאת: IT Support. עקב שדרוג אבטחה, אפס את סיסמתך תוך 24 שעות בקישור המצורף אחרת חשבונך יושבת.” — משלב **Scarcity/Urgency** + **Authority** (IT) + **Fear** (השבתה).

```
./gophish                # ממשק ב - https://localhost:3333
# Landing Pages → Import Site (שבט) → Capture Credentials
# Email Templates → HTML עם {{.URL}}
```

15.8 — צור Group עם המייל שלך בלבד, הרץ Campaign, ובדוק בלשונית / Email Opened Results: Clicked Link / Submitted Data נרשמים.

15.9 — evilginx יושב כ-reverse proxy בין הקורבן לאתר האמיתי; הקורבן מתחבר (כולל MFA) דרכו, ו-evilginx גונב את ה-session cookie אחרי האימות. עם ה-cookie התוקף נכנס בלי לעבור MFA שוב → מוכיח ש-2FA לא עוצר פישנינג מתקדם (אך כן מקשה).

אתגר מסכם — מבנה דוח מודעות

<דוח סימולציית פישנינג – >ארגון

היקף

בהרשאת ההנהלה, "IT עובדים", מייל "איפוס סיסמת 120

תוצאות (ללא שמות)

- 68% פתחו את המייל:
- 31% לחצו על הלינק:
- 12% הזינו פרטים:

ניתוח

.שילוב סמכות+דחיפות היה יעיל; מחלקת המכירות הכי חשופה

המלצות

1. הדרכת מודעות + סימולציות רבעוניות
2. בכל המערכות MFA אכיפת
3. סינון אנטי-פישנינג + SPF/DKIM/DMARC
4. כפתור "דווח על פישנינג" בקליינט המייל

אתיקה

.התוצאות מוצגות כאחוזים בלבד – ללא זיהוי עובדים
המטרה: חינוך ושיפור, לא ענישה

עברת? יש לך דוח מודעות פישנינג אתי ומקצועי. המשך למודול 16.